

# AdvocateAuroraHealth

|                                                                                                                                                                                                                                                                                        |                                                                                                                                           |                                                 |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------|
| <b>Title:</b> AAH Information Classification                                                                                                                                                                                                                                           |                                                                                                                                           | <b>Document Number:</b> 2489                    |
| <b>Document Type:</b> <input checked="" type="checkbox"/> Policy <input type="checkbox"/> Procedure <input type="checkbox"/> Guideline <input type="checkbox"/> Other                                                                                                                  |                                                                                                                                           | <b>Last Review/Revision Date:</b><br>12/31/2020 |
| <b>Content Applies to Patient Care:</b><br>(Select all that apply)<br><br><input type="checkbox"/> Adults<br><input type="checkbox"/> Pediatrics (Under 18)                                                                                                                            | <b>Content Applies to:</b><br>(Select One)<br><br><input type="checkbox"/> Clinical<br><input checked="" type="checkbox"/> Administrative | <b>Next Review Date:</b> 12/31/2023             |
|                                                                                                                                                                                                                                                                                        |                                                                                                                                           | <b>Effective Date:</b> 12/31/2020               |
| <b>Scope:</b> <input checked="" type="checkbox"/> AAH System <input type="checkbox"/> ACH <input type="checkbox"/> AAH IL Only <input type="checkbox"/> AAH WI Only <input type="checkbox"/> Site Only (Location Name):<br><input type="checkbox"/> Department Only (Department Name): |                                                                                                                                           |                                                 |

## I. PURPOSE

This policy outlines the expectations for classifying information at Advocate Aurora Health (AAH). Information Classification ensures the protection of AAH data is consistent with all applicable laws and regulations, particularly with respect to protected health information.

## II. SCOPE

This policy applies to Advocate Aurora Health, Inc. and any entity or facility owned and controlled by Advocate Aurora Health.

## III. DEFINITIONS/ABBREVIATIONS

**Advocate Aurora Team Member:** Anyone employed by AAH who provides services on behalf of AAH. All AAH Team Members are expected to abide by AAH policies and procedures. All AAH Team members are eligible to receive access to internal AAH systems, as required to perform assigned duties.

**Advocate Aurora Information:** All information that is owned by Advocate Aurora or owned by vendors, subcontractors, and/or business associates but provided to Advocate Aurora. For clarification purposes only, information remains "Advocate Aurora Information" even if it is in the possession and under the control of a vendor, subcontractor, and/or business associate.

**Availability:** The expectation that information is accessible when needed.

**Business Associate** - Shall have the same meaning as the term "business associate" at 45 CFR §160.103.

**Confidentiality:** The expectation that only authorized individuals, processes, and systems will have access to AAH information.

**De-identified Information:** Advocate Aurora Information that has been de-identified (a) in accordance with all applicable laws and regulations (including without limitation HIPAA (defined below), in the case of PHI); and (b) such that it does not, and cannot be used to, identify either the subject or the source of the information at any level (i.e., the individual, physician, hospital, health system, etc.). The following Disclosures of De-Identified Information Policy describes the process and specific controls on the de-identification of PHI.

**ePHI:** Protected Health Information (defined below) in electronic form.

**HIPAA:** The Administrative Simplification requirements of the Health Insurance Portability and Accountability Act of 1996 and all regulations promulgated thereunder, including, but not limited to, the Standards for Privacy of Individually Identifiable Health Information, 45 C.F.R. Parts 160 and 164, subparts A and E (“Privacy Regulations”) and the Security Standards for the Protection of Electronic Protected Health Information, 45 C.F.R. Parts 160 and 164, subparts A and C (“Security Regulations”), as amended by the Health Information Technology for Economic and Clinical Health Act, as incorporated in the American Recovery and Reinvestment Act of 2009, and its implementing regulations and guidance issued by the Secretary, all as amended from time to time (the “HITECH Act”).

**Information Custodian:** An AAH Team Member who has administrative responsibility over specific Advocate Aurora Information.

**Integrity:** The expectation that AAH’s information will be protected from intentional, unauthorized, or accidental changes.

**Payment Card Industry Data (or “PCI Data”):** PCI Data includes the following Cardholder Data (CHD) and Sensitive Authentication Data (SAD):

| <b>Cardholder Data includes:</b> | <b>Sensitive Authentication Data includes:</b>            |
|----------------------------------|-----------------------------------------------------------|
| Primary Account Number           | Full track data (magnetic-stripe or equivalent on a chip) |
| Cardholder Name                  | CAV2/CVC2/CVV2/CID                                        |
| Expiration Date                  | PINs/PIN blocks                                           |
| Service Code                     |                                                           |

**Payment Card Industry Data Security Standard (or “PCI DSS”):** Often referred to as just PCI, PCI DSS is a proprietary information security standard for organizations that accept branded credit cards (i.e., American Express, Discover, MasterCard, or Visa) for payment of services, goods or donations. CHD is handled

and stored securely, and SAD must never be stored, regardless of its form (encrypted or clear text).

**Personally Identifiable Information (or “PII”):** Any information about an individual maintained by an agency, including (1) any information that can be used to distinguish or trace an individual's identity, such as name, social security number, date and place of birth, mother's maiden name, or biometric records; and (2) any other information that is linked or linkable to an individual, such as medical, educational, financial, and employment information. This includes, but is not limited to:

- Name
- Social Security Number
- State Issued Driver's license or State ID Number
- Account number or credit/debit card number in combination with security code, access code, or password, etc. permitting access to a person's account.
- DNA Profile
- Biometric Data
- Username or email address in combination with a password or security question and answer that would permit access to an online account

**Protected Health Information (or “PHI”):** Under HIPAA, Protected Health Information is information in any format, for example, paper or electronic which relates to:

- The past, present, or future physical or mental health or condition of an individual;
- The provision of health care to an individual; or
- The past, present, or future payment for the provision of health care to an individual;
- That identifies the individual; or
- There is reasonable basis to believe the information can be used to identify the individual.

The specific elements of PHI consist of:

- Names
- All geographic subdivisions smaller than a state, including street address, city, county, precinct, zip code and their equivalent geocodes, except for the initial three digits of a zip code if, according to the current publicly available data from the Bureau of the Census:

- The geographic unit formed by combining all zip codes with the same three initial digits contains more than 20,000 people; and
- The initial three digits of a zip code for all such geographic units containing 20,000 or fewer people is changed to 000;
- All elements of dates (except year) for dates directly related to an Individual, including birth date, admission/discharge date, date of death; and all ages over 89 and all elements of dates (including year) indicative of such age, except that such ages and elements may be aggregated into a single category of age 90 or older;
- Telephone numbers;
- Fax numbers;
- Email addresses;
- Social security numbers;
- Medical record numbers;
- Health plan beneficiary numbers;
- Account numbers;
- Certificate/license numbers;
- Vehicle identifiers and serial numbers, including license plate numbers;
- Device identifiers and serial numbers;
- Web Universal Resource Locators (URLs);
- Internet Protocol (IP) address numbers;
- Biometric identifiers, including finger and voice prints;
- Full face photographic images and any comparable images; and
- Any other unique identifying number, characteristic, or code

**Subcontractor** - Subcontractor (also known as Third Party): An entity or person other than the vendor that offers to furnish goods or services of any kind under the contract of a vendor.

**Team Member** - Anyone employed with Advocate Aurora Health who provides services on behalf of Advocate Aurora. All Advocate Aurora Team Members are expected to abide by Advocate Aurora policies and procedures. All Advocate Aurora Team Members are eligible to receive access to internal Advocate Aurora systems, as required to perform assigned duties.

**Vendor** - An external party providing paid goods or services to Advocate Aurora Health Care.

#### IV. POLICY

- A. All team members have a responsibility to protect the confidentiality, integrity, and availability of AAH information collected, processed, stored, or transmitted irrespective of the location or medium on which the information resides.
- B. Information must be classified and handled according to its value, legal requirements, sensitivity, and criticality. Protection levels must be established and implemented relative to the information's classification, ensuring against unauthorized access, modification, disclosure, and destruction. For information governed by law and regulations (such as PII and PHI), the protection levels must satisfy the respective, data security and data privacy requirements (e.g. HIPAA).
- C. One of the four Information Classifications in Attachment A shall apply to all AAH Data, whether electronic or physical, and information owners must classify information under their control with an information classification.

**1. Information Classification 4 – Legally-Restricted Confidential Information:**

a) Access to Legally Restricted Confidential Information will be limited to only those individuals who:

- (1) Are permitted to access such information under applicable laws or regulations; and
- (2) Have a need to access such information in order to perform a specific job function.

**2. Information Classification 3 – Advocate Aurora-Restricted Access Confidential Information:**

Access to AAH-Restricted Access Confidential Information will be limited to only those individuals who have a need to access such information in order to perform a specific job function. Access to AAH-Restricted Access Confidential Information may also be limited by contractual and other similar obligations.

**3. Information Classification 2 – Advocate Aurora Internal Confidential Information:**

Access to Advocate Aurora Internal Non-Public Information is not specifically restricted to certain individuals within AAH and may be shared internally at the discretion of the Information Custodian.

**4. Information Classification 1 – Public Information**

This includes all AAH Information that is not sensitive or confidential and is available to the public. This information is frequently available from the Internet and does not require authentication to access it.

D. Information Owners must take into consideration the business needs and legal requirements for sharing or restricting information and the potential risks associated with those needs and requirements.

1. Clearly identify Restricted and Internal Information especially when sharing or providing individuals, departments, vendors, subcontractors, and/or business associates with access.
2. Establish security requirements and expectations for the applications the business unit owns/accesses and which contains AAH information.
3. Provide training and awareness about AAH information handling to users with access to Legally Restricted Confidential Information.
4. Maintain an inventory of their AAH information assets, including all applications that collect, process, store, or transmit their information.
5. Conduct an annual review of information owners, departments and third parties who have been granted access to Legally Restricted Confidential Information.
6. At minimum, Information Owners should assess and update the Information Classification, based on changing usage, sensitivities, law, or other relevant circumstances on an annual basis. NOTE: This requirement does not preclude other markings (e.g. "Subject

to Attorney client privilege”, “Confidential: Health Services Evaluation Data” “Confidential Peer Reviewed Data”, etc.)

7. No Restricted or Internal information may be provided outside of the department or outside of AAH until an agreement is put in place. Contracts with vendors, subcontractors, and/or business associates shall include a "HIPAA Business Associates Agreement" or Purchasing's "Contract Addendum Concerning Protected Information."
8. For PHI data, a HIPAA Business Associates Agreement is required. HIT Risk and Security must review the vendor, subcontractor, or business associate service agreement prior to the contract being signed if the service involves Restricted information.

## **V. PROCEDURE**

Not Applicable

## **VI. CROSS REFERENCES**

- A. Records Retention, Storage, and Destruction
- B. Cybersecurity Incident Response
- C. Business Associate Agreements
- D. Signature Authority and Contracting
- E. Glossary of Defined Terms Used in HIPAA Policies and Procedures

## **VII. RESOURCES AND REFERENCES**

Payment Card Data Security Standards, v 3.2.1: 9.6.1, 9.9.1, 12.6, & 12.8.2.  
The Health Insurance Portability and Accountability Act of 1996  
42 C.F.R., Part 2 Confidentiality of Alcohol and Drug Abuse Patient Records  
State and local laws and regulations regarding cybersecurity

## **VIII. ATTACHMENTS**

- A. Information Classifications

